

Microsoft Security

Guia de Implementação de Hardening Corporativo

Windows 11 Enterprise - Active Directory

Referencial Técnico

CIS Benchmarks v5.0.1 (L1 + L2)

NIST SP 800-171 Rev. 2

NIST SP 800-30 Rev. 1

Âmbito

Windows 11 Enterprise
Active Directory (domínio)

Postos de trabalho corporativos

Versão

1.0 - Junho 2026

Classificação

Uso Interno - Confidencial

1. Introdução e Âmbito

1.1 Objetivo

Este guia estabelece um processo estruturado, quantificável e reproduzível para o endurecimento (hardening) de postos de trabalho Windows 11 Enterprise integrados em domínio Active Directory. Aplica-se a qualquer organização que pretenda elevar a postura de segurança dos seus endpoints de forma auditável e alinhada com referenciais internacionais.

O processo é organizado em três fases sequenciais - Medição, Endurecimento e Validação - e produz métricas objetivas de conformidade que permitem demonstrar o progresso e identificar riscos residuais.

1.2 Âmbito de Aplicação

- Sistema operativo alvo: Windows 11 Enterprise (versão 23H2 ou superior)
- Gestão centralizada via Active Directory e Group Policy Objects (GPO)
- Referencial técnico primário: CIS Benchmarks for Microsoft Windows 11 Enterprise v5.0.1
- Referencial de conformidade regulatória: NIST SP 800-171 Rev. 2
- Análise de risco: NIST SP 800-30 Rev. 1 (via CSET/CISA)

1.3 Referenciais Normativos

Referencial	Versão	Papel na Metodologia
CIS Benchmarks - Windows 11 Enterprise	v5.0.1	Referencial técnico primário - controlos L1 e L2, medição automatizada via CIS-CAT
NIST SP 800-171	Rev. 2	Validação de conformidade regulatória - 110 requisitos organizados em 14 domínios
NIST SP 800-30	Rev. 1	Metodologia de análise de risco - seleção fundamentada de controlos L2
ISO/IEC 27001	2022	Referência conceptual - ciclo PDCA como base da estrutura de fases
DISA STIG	Windows 11	Referência de rigor complementar para ambientes de elevada criticidade

1.4 Estrutura do Processo

O processo divide-se em cinco etapas sequenciais, não reversíveis sem rollback explícito:

Etapa	Fase	Objectivo	Resultado
F1	Medição	Avaliar o estado inicial (L0) antes de qualquer intervenção	Score CIS-CAT baseline + portas expostas + vulnerabilidades CVE
F2a	Endurecimento L1	Aplicar o baseline SCT via GPO de domínio	Score CIS-CAT L1 (~60-65%)
F2b	Análise de Risco	Priorizar controlos L2 com base em risco NIST SP 800-30	Lista de controlos L2 a aplicar/aceitar
F2c	Endurecimento L2	Aplicar controlos L2 seleccionados via GPO dedicada	Score CIS-CAT L2 (~64-70%)
F3	Validação	Confirmar o impacto acumulado com os mesmos instrumentos de F1	Delta F1→F3 quantificado

2. Arquitetura e Pré-requisitos

2.1 Arquitetura de Referência

A implementação requer quatro componentes funcionais distintos, que podem corresponder a máquinas físicas, virtuais ou híbridas, consoante o ambiente da organização:

Componente	Função	Sistema Operativo Recomendado	Localização
Domain Controller (DC)	Active Directory, DNS, GPO, LAPS	Windows Server 2022 (Core ou Desktop)	Rede interna corporativa
Posto de Trabalho Alvo (WS)	Alvo do hardening - endpoint Windows 11	Windows 11 Enterprise v23H2+	Rede interna corporativa
Estação de Auditoria (AUD)	Nmap e OpenVAS - perspectiva externa	Kali Linux (ou qualquer Linux)	Mesma sub-rede do alvo
PC de Avaliação de Risco	CSET/NIST SP 800-30 - ferramenta standalone	Windows 10/11 (qualquer edição)	Qualquer (não requer acesso à rede do alvo)

1 Isolamento de Rede para Auditoria

Durante as fases de auditoria (F1 e F3), a estação de auditoria deve operar na mesma sub-rede que o alvo, sem acesso à Internet. Isto garante que os resultados dos scans reflectem exclusivamente o estado interno do sistema e não dependem de serviços externos. Em ambientes de produção, usar uma VLAN de auditoria dedicada.

2.2 Software Necessário - Onde Instalar e Onde Executar

Ferramenta	Versão Mínima	Instalar em	Executar em	Custo	URL
CIS-CAT Lite	4.63.0+	Posto de trabalho alvo (WS)	WS - localmente (PowerShell)	Gratuito	cisecurity.org/cis-cat-lite
Microsoft SCT + LGPO.exe	Win11 v23H2	Domain Controller (DC)	DC - PowerShell Admin	Gratuito	microsoft.com/security/compliance-toolkit
RSAT (GroupPolicy)	Incluído no WS 2022	Domain Controller (DC)	DC - PowerShell Admin	Gratuito (incluído)	microsoft.com/download/rsat
Nmap	7.9+	Estação de auditoria (AUD)	AUD - contra o alvo (WS)	Open Source	nmap.org
OpenVAS / Greenbone CE	25.x	Estação de auditoria (AUD)	AUD - browser local (9392)	Open Source	greenbone.net/community
CSET (CISA)	v13+	PC de avaliação de risco	PC avaliação - browser local	Gratuito	github.com/cisagov/cset/releases

2.3 Pré-requisitos de Rede

- Posto de trabalho alvo (WS) deve ter a mesma sub-rede que a estação de auditoria (AUD)
- O WS deve estar ingressado no domínio Active Directory e ter o objeto computador na OU correta
- O DC deve ter acesso de escrita ao SYSVOL para distribuição de GPOs
- A AUD deve ter conectividade TCP/UDP sem restrições para o WS durante os scans
- O CSET é instalado num PC qualquer - não requer acesso à rede do alvo

2.4 Sequência de Snapshots / Pontos de Restauro

Antes de cada intervenção, criar um ponto de restauro (snapshot em VM, ou ponto de restauro do sistema em hardware físico). Esta disciplina garante reprodutibilidade e reversibilidade:

Ponto	Nome Sugerido	Criar em
S-00	Instalação Limpa	Após instalação do SO, antes de qualquer configuração
S-01	Baseline Corporativo	Após ingresso no domínio e instalação de software corporativo
S-02	Pré-Hardening (L0)	Após avaliação F1 - antes de qualquer hardening
S-03	Pós-SCT L1	Após aplicação do baseline SCT e avaliação intermédia
S-04	Pós-Análise de Risco	Após CSET - antes de aplicar controlos L2
S-05	Pré-L2	Antes de executar os scripts de controlos L2
S-06	Estado Final Validado	Após avaliação F3 - estado de hardening completo

3. Fase F1 - Medição (Baseline)

Objetivo: obter métricas de conformidade antes de qualquer intervenção de hardening. Estes valores constituem a linha de base (L0) para comparação nas fases subsequentes. Nenhuma alteração de configuração deve ser efetuada nesta fase.

⚠ Ordem Obrigatória

Todos os instrumentos de auditoria (CIS-CAT, Nmap, OpenVAS) devem ser executados ANTES de qualquer alteração de configuração. Os resultados desta fase são os valores de referência para o cálculo do delta de melhoria.

3.1 Avaliação CIS-CAT - Posto de Trabalho (WS)

Executar no posto de trabalho alvo, em PowerShell com privilégios de Administrador local:

```
# Passo 1 - Navegar para a pasta do CIS-CAT Lite
cd C:\Tools\CIS-CAT\Assessor

# Passo 2 - Executar avaliação (perfil L1 Corporate/Enterprise)
.\Assessor-CLI.bat `
  -b "benchmarks\CIS_Microsoft_Windows_11_Enterprise_Benchmark_v5.0.1-xccdf.xml" `
  -p "Level 1 (L1) - Corporate/Enterprise" `
  -rd "C:\Temp\Reports"

# Passo 3 - Guardar o relatório HTML gerado em C:\Temp\Reports\
# O nome do ficheiro inclui o timestamp - ex:
# WS01-CIS_Microsoft_Windows_11_Enterprise_Benchmark-20260606T111934Z.html
```

ℹ Limitação do CIS-CAT Lite

O CIS-CAT Lite não inclui benchmark para Windows Server 2022. A avaliação do Domain Controller é efectuada por verificação manual (Secção 3.2). Esta limitação é inerente à versão gratuita da ferramenta - a versão Pro (licença paga) inclui benchmarks para todos os sistemas operativos Microsoft.

Resultado típico numa instalação base sem hardening: 20-30% (aproximadamente 85-100 Pass / 285-305 Fail de 391 controlos scored).

3.2 Verificação Manual - Domain Controller (DC)

Executar no DC em PowerShell com privilégios de Administrador de Domínio:

```
# GPOs aplicadas ao DC
gpresult /scope computer /v > C:\Reports\gpresult_dc.txt

# Políticas de auditoria avançada
auditpol /get /category:* > C:\Reports\auditpol_dc.txt
```

```
# Estado dos serviços críticos do AD
Get-Service adws, dns, kdc, netlogon | Select-Object Name, Status

# SMBv1 deve estar desactivado
Get-SmbServerConfiguration | Select-Object EnableSMB1Protocol

# Verificar configuração de password e lockout
net accounts
```

3.3 Varrimento de Rede - Nmap (da Estação de Auditoria)

Executar na estação de auditoria (AUD) contra o posto de trabalho alvo e o Domain Controller:

```
# Scan completo ao posto de trabalho alvo
# Substituir <IP_WS> pelo endereço IP real do posto de trabalho
sudo nmap -Pn -sV -sC -p- \
  -oN ./reports/F1_nmap_ws_baseline.txt \
  <IP_WS>

# Scan completo ao Domain Controller
# Substituir <IP_DC> pelo endereço IP real do DC
sudo nmap -Pn -sV -sC -p- \
  -oN ./reports/F1_nmap_dc_baseline.txt \
  <IP_DC>

# Resumo rápido de portas abertas
grep "^[0-9]" ./reports/F1_nmap_ws_baseline.txt
```

Parâmetros: -Pn (não depende de ICMP), -sV (detecção de versão), -sC (scripts NSE padrão), -p- (todas as 65535 portas TCP), -oN (output em texto legível).

3.4 Análise de Vulnerabilidades - OpenVAS (da Estação de Auditoria)

```
# Iniciar os serviços OpenVAS
sudo gvm-start

# Verificar que o scanner está pronto (aguardar 2-3 min)
sudo systemctl status ospd-openvas gvmcd | grep "Active:"

# Aceder à interface web
# https://127.0.0.1:9392 (credenciais: admin / <password definida na instalação>)

# Na interface web - criar Target:
#   Hosts: <IP_WS>
#   Alive Test: Consider Hosts as Alive
#   Port List: All IANA Assigned TCP

# Criar Task:
```

```
# Scanner: OpenVAS Default
# Scan Config: Full and Fast
# Min QoD: 70%

# Iniciar scan e aguardar conclusão (20-40 min)
# Exportar relatório em formato XML: Reports → Export
```

Resultado esperado numa instalação base típica: 0 Critical / 0 High. A ausência de CVEs críticos não indica postura de segurança robusta - decorre da superfície de ataque remota limitada, não de controlos de hardening aplicados.

3.5 Verificações Adicionais de Configuração

No posto de trabalho (WS), em PowerShell como Administrador:

```
# Políticas de conta (password, lockout)
net accounts

# Auditoria avançada actual
auditpol /get /category:*

# SMB signing e versão
Get-SmbServerConfiguration | Select-Object RequireSecuritySignature,
EnableSMB1Protocol, EnableSMB2Protocol

# Serviços activos
Get-Service | Where-Object {$_.Status -eq "Running"} | Select-Object Name, DisplayName
| Sort-Object Name
```

3.6 Checklist Fase F1

- ☐ CIS-CAT executado no WS - score L0 registado
- ☐ Relatório HTML do CIS-CAT guardado com timestamp
- ☐ Ponto de restauro S-02 criado ("Pré-Hardening L0")
- ☐ Verificação manual DC executada (gpresult, auditpol, SMBv1, serviços AD)
- ☐ Scan Nmap executado contra WS e DC - número de portas abertas registado
- ☐ Scan OpenVAS executado - severidade máxima registada
- ☐ Todos os ficheiros de evidência guardados em pasta organizada por data/fase

4. Fase F2a - Endurecimento L1 (SCT Baseline)

Objetivo: aplicar o Microsoft Security Compliance Toolkit (SCT) Windows 11 v23H2 Security Baseline através de GPOs geridas centralmente pelo Domain Controller. Este passo endereça a generalidade das não-conformidades identificadas nas categorias de Administrative Templates (18, 18.10) e Advanced Audit Policy (17).

⚠ Pré-requisito

Confirmar que o ponto de restauro S-02 existe e é válido antes de prosseguir. Em caso de impacto operacional inaceitável, reverter para S-02 e excluir o controlo problemático da GPO.

4.1 Preparação do Active Directory

No DC, confirmar que o objeto computador do WS está na OU correta para receber as GPOs:

```
# Verificar localização actual do objecto computador
# Substituir <NOME_WS> pelo nome NetBIOS do posto de trabalho
Get-ADComputer -Identity "<NOME_WS>" -Properties DistinguishedName |
    Select-Object Name, DistinguishedName

# Se necessário - criar OU de postos de trabalho
New-ADOrganizationalUnit -Name "Workstations" `
    -Path "DC=<dominio>,DC=<tld>" `
    -ProtectedFromAccidentalDeletion $true

# Mover o objecto computador para a OU
Move-ADObject `
    -Identity "CN=<NOME_WS>,CN=Computers,DC=<dominio>,DC=<tld>" `
    -TargetPath "OU=Workstations,DC=<dominio>,DC=<tld>"
```

4.2 Importação e Ligação das GPOs do Baseline SCT

```
# Definir o caminho onde o SCT foi extraído
$sctPath = "C:\SCT\Windows 11 v23H2 Security Baseline\GPOs"
$ou      = "OU=Workstations,DC=<dominio>,DC=<tld>"

# Identificar os nomes das GPOs disponíveis no baseline
Get-ChildItem $sctPath -Directory | ForEach-Object {
    $xml = [xml](Get-Content (Join-Path $_.FullName "gpreport.xml"))
    Write-Host "$($_.Name) => $($xml.GPO.Name)"
}

# Importar e ligar cada GPO
# Repetir para cada GPO identificada no passo anterior
$gpoName = "<NOME_GPO>" # ex: "MSFT Windows 11 23H2 - Computer"
New-GPO -Name $gpoName
Import-GPO -BackupGpoName $gpoName -Path $sctPath -TargetName $gpoName
```



```
New-GPLink -Name $gpoName -Target $ou -LinkEnabled Yes

# Confirmar GPOs ligadas à OU
Get-GPInheritance -Target $ou |
    Select-Object -ExpandProperty GpoLinks |
    Select-Object DisplayName, Enabled, Order
```

4.3 Aplicação das Políticas no Posto de Trabalho

No WS, em PowerShell como Administrador:

```
# Forçar aplicação imediata das GPOs
gpupdate /force

# Gerar relatório RSoP (Resultant Set of Policy)
New-Item -ItemType Directory -Force -Path C:\Temp
gpreport /H C:\Temp\RSoP_pos_SCT.html /f

# Verificar políticas de conta aplicadas
net accounts

# Verificar política de auditoria resultante
auditpol /get /category:*

# Reiniciar para aplicar todas as políticas (obrigatório)
Restart-Computer -Force
```

Após reinício, criar ponto de restauro S-03. Executar nova avaliação CIS-CAT com os mesmos parâmetros da F1. Score típico esperado: 60-65% (+35-40 pp face ao L0).

4.4 Avaliação Intermédia Pós-SCT L1

Repetir CIS-CAT, Nmap e OpenVAS nas mesmas condições da F3:

```
# CIS-CAT pós-SCT L1 - no WS
cd C:\Tools\CIS-CAT\Assessor
.\Assessor-CLI.bat `
    -b "benchmarks\CIS_Microsoft_Windows_11_Enterprise_Benchmark_v5.0.1-xccdf.xml" `
    -p "Level 1 (L1) - Corporate/Enterprise" `
    -rd "C:\Temp\Reports"

# Nmap pós-SCT L1 - na AUD
sudo nmap -Pn -sV -sC -p- \
    -oN ./reports/F2a_nmap_ws_pos_sct.txt \
    <IP_WS>
```

Registar: score CIS-CAT pós-L1, número de portas abertas, e comparar com os valores de F1. As falhas residuais identificadas nesta avaliação são o input para a análise de risco da Fase F2b.

5. Fase F2b - Análise de Risco (NIST SP 800-30)

Objetivo: priorizar os controlos L2 a aplicar com base numa análise de risco formal, em vez de aplicar cegamente o baseline L2 completo. Este passo diferencia uma abordagem de hardening madura de uma aplicação mecanicista de políticas.

5.1 Instalação e Configuração do CSET

1. Descarregar o instalador: github.com/cisagov/cset/releases (CSETStandAlone.exe)
2. Instalar no PC de avaliação de risco como administrador - aceitar opções por omissão
3. Lançar o CSET: atalho no Desktop ou C:\Program Files\CISA\CSET\
4. Criar conta local (não requer ligação à Internet)
5. Criar nova avaliação: New Assessment → NIST SP 800-171 Rev. 2

5.2 Preenchimento do Questionário NIST SP 800-171

O CSET apresenta 110 perguntas organizadas em 14 domínios. Responder com base no estado atual do sistema (pós-SCT L1). Orientações por domínio:

Domínio NIST	Req.	Critério de Resposta
Access Control (3.1)	22	Yes se o controlo está activo no AD/GPO; No se ausente
Audit and Accountability (3.3)	9	Yes se auditpol regista as subcategorias relevantes
Configuration Management (3.4)	9	Yes se existe baseline SCT aplicado; No se manual/ausente
Identification and Authentication (3.5)	11	Yes para password policy, lockout, Kerberos; No para MFA
Incident Response (3.6)	3	No se não existe processo formal documentado
Maintenance (3.7)	6	Avaliar existência de procedimentos de manutenção
Media Protection (3.8)	9	No se BitLocker não está activo / media não controlada
Personnel Security (3.9)	2	No em ambientes sem processo RH formal
Physical Protection (3.10)	6	Depende do ambiente físico real
Risk Assessment (3.11)	3	Yes - a execução deste processo é evidência suficiente
Security Assessment (3.12)	4	Yes - a execução deste guia constitui evidência
System and Comms Protection (3.13)	16	Parcial - firewall activa mas sem segmentação avançada
System and Info Integrity (3.14)	7	Yes para Defender/AV; No para SIEM/monitorização
Awareness and Training (3.2)	3	No se não existe programa formal de formação

5.3 Interpretação do Relatório CSET

Após submeter o questionário, o CSET gera um relatório com score por domínio e ranking de prioridades. Exportar em PDF: Results → Generate Report.

Score típico após SCT L1: 35-45% (reflexo de que o NIST SP 800-171 inclui requisitos organizacionais e físicos não cobertos por configurações técnicas de endpoint).

5.4 Critérios de Selecção dos Controlos L2

Decisão	Critério CSET	Impacto Operacional	Acção
APLICAR	Risco High ou Very High	Baixo ou Médio	Implementar via GPO L2
ACEITAR	Risco Moderate ou inferior	Qualquer	Documentar como risco residual aceite
ACEITAR	Qualquer nível de risco	Alto (rutura operacional)	Documentar limitação e justificação
REVER	Risco High, impacto desconhecido	A avaliar	Testar em ambiente de homologação primeiro

Os controlos classificados como ACEITAR devem ser documentados como risco residual com justificação técnica. Esta documentação é essencial para auditoria e para demonstrar que a decisão foi consciente.

6. Fase F2c - Endurecimento L2 (Controlos Seleccionados)

Objetivo: aplicar os controlos L2 seleccionados na análise de risco, via GPO dedicada separada do baseline SCT. Esta separação permite gerir os controlos L2 independentemente e facilita rollback selectivo.

6.1 Criar GPO Dedicada L2 no Domain Controller

```
# No DC - criar nova GPO para os controlos L2
$gpoL2Name = "<ORGANIZACAO> - <NOME_WS> L2 Hardening"
$sou       = "OU=Workstations,DC=<dominio>,DC=<tld>"

New-GPO -Name $gpoL2Name
New-GLink -Name $gpoL2Name -Target $sou -LinkEnabled Yes

# Confirmar GPO criada
Get-GPO -Name $gpoL2Name | Select-Object DisplayName, Id, GpoStatus
```

6.2 Controlos L2 de Referência - Implementação via GPO

Os controlos abaixo são os de maior impacto e menor risco operacional, validados na prática. Adaptar à análise de risco da organização:

Control o CIS	Descrição	Chave de Registo / Mecanismo	Valor
1.2.1	Account Lockout Duration	GptTmpl.inf → [System Access] LockoutDuration	≥ 15
1.2.4	Reset Lockout Counter	GptTmpl.inf → [System Access] ResetLockoutCount	≥ 15
5.23	RPC Locator - Disabled	GptTmpl.inf → [Service] RpcLocator,4	Disabled (4)
5.30	SSDP Discovery - Disabled	GptTmpl.inf → [Service] SSDPSRV,4	Disabled (4)
5.31	UPnP Device Host - Disabled	GptTmpl.inf → [Service] upnphost,4	Disabled (4)
9.1.4 / 9.2.4 / 9.3.6	Firewall Logging (3 perfis)	HKLM\SOFTWARE\Policies\Microsoft\WindowsFirewall*\Logging	LogFilePath + 16384 KB
17.2.1	Audit Applicatio	audit.csv → GUID {0CCE9236-...}	Success and Failure (3)

Control o CIS	Descrição	Chave de Registro / Mecanismo	Valor
	n Group Mgmt		
17.5.3	Audit Logoff	audit.csv → GUID {0CCE9216-...}	Success (1)
17.7.3	Audit Authorizat ion Policy Change	audit.csv → GUID {0CCE9230-...}	Success (1)
18.6.4.1	Disable mDNS	HKLM\SOFTWARE\Policies\Microsoft\Windows NT\DNSClient → EnableMulticast	0
18.6.7.4	SMB Client Auth Rate Limiter	HKLM\SOFTWARE\Policies\Microsoft\Windows\LanmanWorks tation → EnableAuthRateLimiter	1
18.6.7.6	SMB Client Min Version 3.1.1	HKLM\SOFTWARE\Policies\Microsoft\Windows\LanmanWorks tation → MinSMB2Dialect	785 (0x0311)
18.6.8.6	SMB Server Min Version 3.1.1	HKLM\SOFTWARE\Policies\Microsoft\Windows\LanmanServer → MinSMB2Dialect	785 (0x0311)
18.6.14. 1	Hardened UNC Paths	HKLM\SOFTWARE\Policies\Microsoft\Windows\NetworkProvi der\HardenedPaths	RequireMutualAuthenticat ion=1,...
18.7.1	Print Spooler - No Remote	HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers → RegisterSpoolerRemoteRpcEndPoint	2
18.7.12/ 13	Point and Print - Elevation	HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers\PointAndPrint	NoWarning=0, UpdatePrompt=0
18.9.3.1	Command Line in Event 4688	HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policie s\System\Audit → ProcessCreationIncludeCmdLine_Enabled	1
18.9.27. 2	LSASS Protected Process (PPL)	HKLM\SYSTEM\CurrentControlSet\Control\Lsa → RunAsPPL	2 (UEFI Lock)

6.3 Script de Referência - Aplicação via PowerShell

Cada controlo é aplicado via Set-GPRegistryValue no DC. Exemplo para os controlos SMB:

```
# Exemplo - Controlos SMB (adaptar $gpOL2Name ao nome real)
$gpOL2Name = "<ORGANIZACAO> - <NOME_WS> L2 Hardening"

# CIS 18.6.7.6 - SMB Client: versão mínima 3.1.1
Set-GPRegistryValue -Name $gpOL2Name `
  -Key "HKLM\SOFTWARE\Policies\Microsoft\Windows\LanmanWorkstation" `
  -ValueName "MinSMB2Dialect" -Type DWord -Value 785

# CIS 18.9.27.2 - LSASS Protected Process Light com UEFI Lock
Set-GPRegistryValue -Name $gpOL2Name `
  -Key "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" `
  -ValueName "RunAsPPL" -Type DWord -Value 2

# CIS 18.7.1 - Print Spooler: desactivar ligações remotas
Set-GPRegistryValue -Name $gpOL2Name `
  -Key "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers" `
  -ValueName "RegisterSpoolerRemoteRpcEndPoint" -Type DWord -Value 2

# Repetir para cada controlo seleccionado na análise de risco
```

6.4 Aplicação e Verificação no Posto de Trabalho

```
# No WS - forçar aplicação da GPO L2
gpupdate /force
Restart-Computer -Force

# Após reinício - confirmar GPO L2 em Applied Group Policy Objects
gpresult /r

# Gerar RSoP completo pós-L2
gpresult /H C:\Temp\RSoP_pos_L2.html /f
gpresult /v > C:\Temp\RSoP_pos_L2_verbose.txt
```

Confirmar que a GPO L2 aparece em "Applied Group Policy Objects". Criar ponto de restauro S-06 após confirmação de estabilidade operacional.

7. Fase F3 - Validação

Objectivo: repetir os três instrumentos de auditoria nas mesmas condições da Fase F1 e calcular o delta de melhoria acumulado. Os resultados desta fase são as métricas finais do programa de hardening.

7.1 CIS-CAT Pós-L2

```
# No WS - mesmos parâmetros da F1
cd C:\Tools\CIS-CAT\Assessor
.\Assessor-CLI.bat `
  -b "benchmarks\CIS_Microsoft_Windows_11_Enterprise_Benchmark_v5.0.1-xccdf.xml" `
  -p "Level 1 (L1) - Corporate/Enterprise" `
  -rd "C:\Temp\Reports"

# Guardar relatório com timestamp para comparação com F1 e F2a
```

Score esperado após L1 + L2 seleccionado: 63-68%. O incremento L2 é tipicamente de 2-5 pp adicionais face ao L1, reflectindo a natureza complementar (não substituta) dos controlos seleccionados.

7.2 Nmap Pós-L2

```
# Na AUD - mesmos parâmetros da F1
sudo nmap -Pn -sV -sC -p- \
  -oN ./reports/F1_nmap_ws_pos_l2.txt \
  <IP_WS>

# Comparar número de portas abertas com F3
echo "=== F3 ===" && grep "^[0-9]" ./reports/F1_nmap_ws_baseline.txt
echo "=== F5 ===" && grep "^[0-9]" ./reports/F1_nmap_ws_pos_l2.txt

# Verificar SMB 3.1.1 e message signing
grep -A3 "smb2-security-mode" ./reports/F1_nmap_ws_pos_l2.txt
```

7.3 OpenVAS Pós-L2

```
# Na AUD - reutilizar a Task criada em F1 ou criar nova
sudo gvm-start
# https://127.0.0.1:9392
# Scans → Tasks → Start (na task existente)
# ou criar nova Task com os mesmos parâmetros

# Aguardar conclusão e exportar relatório XML
# Confirmar: 0 Critical / 0 High
```

7.4 Tabela de Resultados Comparativos

Preencher com os valores reais obtidos no programa de hardening da organização:

Métrica	F1 (L0 - Baseline)	F2a (L1 - SCT)	F1 (L2 - Final)	Delta F1→F3
Score CIS-CAT	____%	____%	____%	+____ pp
Controlos Pass	____	____	____	+____
Controlos Fail	____	____	____	-____
Portas abertas (Nmap)	____	____	____	-____
SMB versão mínima	____	____	3.1.1	____
SMB signing obrigatório	____	Sim	Sim	____
OpenVAS Critical/High	0 / 0	0 / 0	0 / 0	Inalterado
NIST SP 800-171 (CSET)	____	____%	____	____

7.5 Checklist Final de Validação

- ☐ CIS-CAT F3 executado com os mesmos parâmetros de F1
- ☐ Relatório HTML CIS-CAT F3 guardado com timestamp
- ☐ Nmap F5 executado - comparação com F1 efectuada
- ☐ SMB 3.1.1 com message signing required confirmado
- ☐ OpenVAS F3 executado - 0 Critical / 0 High confirmado
- ☐ Tabela de resultados comparativos preenchida com valores reais
- ☐ RSoP_pos_L2.html gerado e guardado
- ☐ Ponto de restauro S-06 criado ("Estado Final Validado")
- ☐ Todos os ficheiros de evidência organizados por fase
- ☐ Risco residual documentado (controlos classificados como ACEITAR)

8. Referências e Recursos

Recurso	Descrição	URL
CIS Benchmarks - Windows 11 Enterprise v5.0.1	Referencial técnico primário - controles L1 e L2	cisecurity.org/benchmark/microsoft_windows_desktop
CIS-CAT Lite	Ferramenta de avaliação automatizada CIS	cisecurity.org/cis-cat-lite
Microsoft SCT (LGPO.exe)	Security Compliance Toolkit - baseline Windows 11 v23H2	microsoft.com/security/compliance-toolkit
NIST SP 800-171 Rev. 2	Protecting Controlled Unclassified Information - 110 requisitos	csrc.nist.gov/publications/detail/sp/800-171/rev-2/final
NIST SP 800-30 Rev. 1	Guide for Conducting Risk Assessments	csrc.nist.gov/publications/detail/sp/800-30/rev-1/final
CSET - Cyber Security Evaluation Tool	Ferramenta CISA para avaliação NIST SP 800-171	github.com/cisagov/cset/releases
Nmap	Network mapper - varrimento de portas e serviços	nmap.org
OpenVAS / Greenbone Community Edition	Scanner de vulnerabilidades open source	greenbone.net/community-edition
ISO/IEC 27001:2022	Sistema de Gestão de Segurança da Informação	iso.org/standard/27001
DISA STIG - Windows 11	Security Technical Implementation Guide	public.cyber.mil/stigs